Lời thuyết trình – TAKA10 – Phân loại đa nhãn họ mã độc bằng học sâu kết hợp Attention

Slide 1. Phân loại đa nhãn họ mã độc bằng mô hình học sâu kết hợp cơ chế Attention

Chào thầy/cô và các bạn. Em là Lê Tuấn Lương, mã số học viên 250202013. Đề tài TAKA10 của em là phân loại đa nhãn họ mã độc Windows bằng mô hình học sâu kết hợp cơ chế Attention, kết hợp ba nguồn bằng chứng: chữ ký, cấu trúc PE tĩnh và hành vi động trong sandbox.

Slide 2. Bài trình bày trả lời sáu câu hỏi

Bài trình bày của em đi theo sáu câu hỏi: bài toán là gì, dữ liệu lấy từ đâu, mô hình hoạt động ra sao, kết quả tốt đến đâu, dùng thử thế nào, và cuối cùng là còn thiếu gì, làm gì tiếp.

Slide 3. Cho một mẫu mã độc Windows, đoán xem nó thuộc họ nào

Bài toán rất đơn giản để phát biểu: cho một mẫu mã độc Windows, hệ thống đoán xem nó thuộc họ nào. Đầu vào là report từ sandbox, tức mẫu đã được chạy trong máy ảo và ghi lại hành vi, hoặc chỉ là file PE. Đầu ra là danh sách họ xếp theo điểm, và nếu không đủ chắc thì trả UNKNOWN thay vì đoán bừa. Gọi là đa nhãn vì một mẫu có thể mang nhiều nhãn họ. Mục tiêu đặt ra là đoán đúng ngay lần đầu từ 85% trở lên trên tập test.

Slide 4. Nhìn một mẫu từ ba góc rồi cho chúng đối chiếu nhau

Ý tưởng chính: thay vì chỉ nhìn một loại thông tin, mô hình nhìn mẫu từ ba góc. Góc chữ ký hỏi mẫu có khớp dấu hiệu đã biết nào không. Góc cấu trúc tĩnh hỏi file được xây dựng ra sao, dùng những hàm nào. Góc hành vi động hỏi khi chạy trong sandbox thì nó làm gì. Mỗi góc riêng lẻ đều có thể bị che giấu, ví dụ packer làm cấu trúc tĩnh gần như giống nhau. Khi cho ba góc đối chiếu nhau thì chỗ này thiếu, chỗ kia bù.

Slide 5. WinMET: report sandbox mã độc thật, có sẵn nhãn họ

Dữ liệu là WinMET, công bố năm 2025, gồm 31.844 report sandbox của mã độc thật. Mỗi report đã có nhãn họ do công cụ AVClass gán. AVClass gộp tên từ nhiều phần mềm antivirus, nên nhãn có nhiễu, em gọi là nhãn yếu. Dữ liệu rất lớn: mỗi phần nén 2,4 GB nhưng giải nén ra khoảng 154 GB, nên em giải nén ngay trong bộ nhớ và không bao giờ chạy mẫu. Tập train hiện có 8.500 report, gấp năm lần bản đầu.

Slide 6. Chia dữ liệu như ra đề: đề thi không trùng bài tập

Cách chia dữ liệu giống như ra đề thi. Train là bài tập để mô hình học. Validation là thi thử, dùng để chọn phiên bản tốt nhất. Calibration dùng để đặt ngưỡng tin cậy. Test là thi thật, chỉ chấm đúng một lần khi đã chốt mô hình, có khóa để không thể chấm lại. Một điểm quan trọng: WinMET nén theo từng khối, các report trong cùng khối thường rất giống nhau. Nếu chia ngẫu nhiên từng report thì sẽ bị lộ đề, nên em xếp nguyên khối vào cùng một tập.

Slide 7. Mô hình làm bốn bước: đọc, tóm tắt, đối chiếu, kết luận

Mô hình làm bốn bước. Bước một, đọc: tách mẫu thành các mảnh nhỏ gọi là token, theo ba góc chữ ký, cấu trúc tĩnh và hành vi. Bước hai, tóm tắt: mỗi góc tự tìm điểm quan trọng của mình bằng self-attention; riêng đồ thị hành vi dùng graph attention. Bước ba, đối chiếu, là điểm chính của đề tài: các góc hỏi chéo nhau bằng cross-attention để ghép bằng chứng. Bước bốn, kết luận: chấm điểm từng họ, nếu không đủ chắc thì trả UNKNOWN. Dòng chữ xám bên dưới là tên kỹ thuật tương ứng trong báo cáo.

Slide 8. Attention: mô hình tự quyết định nên chú ý vào đâu

Attention có thể hiểu đơn giản là mô hình tự quyết định nên chú ý vào đâu. Mỗi token hỏi các token khác xem ai liên quan tới mình; token càng liên quan càng được chú ý nhiều. Khi làm việc này giữa hai góc khác nhau thì gọi là cross-attention. Ví dụ minh họa: một hàm import dùng để tải file từ mạng, nhìn riêng thì chưa chắc độc hại. Nhưng khi nối với sự kiện ghi file rồi chạy chính file đó trong hành vi, hai dấu hiệu yếu ghép lại thành bằng chứng mạnh.

Slide 9. Ba con số dùng xuyên suốt phần kết quả

Trước khi xem kết quả, em giải thích ba con số. Top-1 là tỉ lệ đoán đúng ngay lần đầu; để so sánh, nếu luôn đoán họ phổ biến nhất thì được 22,1 phần trăm. Top-3 là tỉ lệ đáp án đúng nằm trong ba lựa chọn đầu. Macro-F1 tính trung bình đều trên mọi họ, nên họ hiếm có trọng lượng ngang họ phổ biến. Tất cả số tiếp theo đều đo trên validation gồm 181 report thuộc các họ mô hình đã học; tập test chỉ chấm một lần ở cuối.

Slide 10. Train đủ lâu: top-1 tăng từ 46% lên 64–70%

Kết quả chính: run cũ bị dừng ở epoch 4 khi đường cong vẫn đang đi lên. Train lại đủ 14 epoch, top-1 validation tăng từ 46% lên 64 đến 70%. Checkpoint được chọn theo mAP là epoch 10 với top-1 64,1% và top-3 80,1%; epoch 14 đạt top-1 cao nhất 70,2% nhưng mAP thấp hơn. Validation chỉ có 181 mẫu, nên chênh lệch 2 đến 4 điểm giữa các epoch phần lớn là nhiễu. Vẫn còn cách mục tiêu 85%.

Slide 11. Tắt đối chiếu chéo, họ hiếm bị đoán sai nhiều hơn hẳn

Để biết bước đối chiếu chéo có thật sự giúp ích, em thử tắt nó đi khi suy luận, trên cùng 181 report validation. Top-1 tổng thể không đổi, vẫn 60,2 phần trăm, vì các họ phổ biến vẫn được đoán đúng. Nhưng macro-F1, tức điểm tính đều cho cả họ hiếm, giảm từ 24 xuống 14 phần trăm. Nghĩa là cross-attention giúp chủ yếu cho các họ hiếm. Ngoài ra, che các cạnh của đồ thị hành vi làm top-1 giảm 2,8 điểm. Số đo này trên checkpoint cũ ở epoch 4.

Slide 12. Chỉ trả lời khi đủ tự tin thì độ chính xác lên 90,8%

Trong thực tế, một hệ thống biết nói "tôi không chắc" có giá trị hơn một hệ thống luôn đoán. Nếu trả lời mọi report, mô hình đúng 64,1 phần trăm. Nếu chỉ trả lời khi điểm vượt ngưỡng, độ chính xác lên 90,8 phần trăm, đổi lại chỉ trả lời được 54,1 phần trăm số report, phần còn lại trả UNKNOWN để người phân tích xem tay. Ngưỡng được đặt trên tập calibration riêng. Với 47 report thuộc họ mô hình chưa học, chỉ 3 report bị trả lời nhầm. Em không dùng 90,8 phần trăm thay cho top-1 toàn phần.

Slide 13. Dashboard phân tích mẫu mà không bao giờ chạy mẫu

Phần ứng dụng là một dashboard chạy cục bộ. Dashboard tự chọn mô hình theo đầu vào: report có hành vi thì dùng mô hình ba góc train trên WinMET; chỉ có file PE thì dùng mô hình tĩnh train trên EMBER2024. Có ba lớp an toàn: file PE được đọc trong sandbox của macOS, cấm mạng, ghi file và tạo process; nếu đầu vào có quá ít token quen thuộc thì trả UNKNOWN; và checkpoint được khóa bằng SHA-256, dữ liệu sai phiên bản chuẩn hóa sẽ bị từ chối.

Slide 14. Demo: 20 report validation, mỗi report khoảng 0,1 giây

Phần demo: em mở dashboard chạy ngay trên máy. Bước một, nạp 20 report lấy từ tập validation; mỗi report mất khoảng 0,1 giây. Kết quả hiện họ dự đoán, điểm tin cậy và trọng số attention theo từng góc. Trong 20 report, mô hình chấp nhận trả lời 9 report và đúng 8; 11 report còn lại trả UNKNOWN thay vì đoán. Bước cuối, em upload một file PE để xem luồng phân tích tĩnh trong sandbox.

Slide 15. Máy 16 GB: tiết kiệm bộ nhớ để train nhanh gấp đôi

Một khó khăn thực tế là phần cứng: máy chỉ có 16 GB RAM, trong khi bản train cũ chiếm khoảng 34 GB và phải dùng swap liên tục. Em chuyển mỗi report sang dạng số một lần rồi bỏ dữ liệu thô, bộ nhớ cho mỗi report giảm từ 2,66 xuống 0,34 MB, và mỗi epoch giảm từ khoảng 14 xuống 6,5 phút. Em đã kiểm chứng tối ưu này không làm thay đổi kết quả: train loss trùng đến bảy chữ số khi bật và tắt.

Slide 16. Sáu phiên bản, mỗi bản sửa một vấn đề của bản trước

Đây là toàn bộ quá trình, gồm sáu phiên bản. Bản một là mô hình tĩnh trên EMBER2024, 34 nghìn mẫu, attention đạt top-1 71,9 phần trăm so với 64,6 của bag-of-tokens. Bản hai chuyển sang WinMET với ba nhánh, pilot 1.000 report, attention

hơn bag về mAP. Bản ba thêm quan hệ giữa các process, bản bốn thêm liên kết tài nguyên và mở rộng lên 2.500 report, nhưng dừng ở epoch 4 do tắt máy. Bản năm tối ưu bộ nhớ để train đến hội tụ, đạt 64,1 phần trăm, và đây là checkpoint dùng cho demo. Bản sáu tăng dữ liệu lên năm lần; ở đây em thêm một baseline TF-IDF cộng hồi quy logistic và nó đạt 71,6 phần trăm, cao hơn mô hình attention. Lưu ý mỗi dòng đo trên validation riêng nên chỉ so được trong cùng một dòng.

Slide 17. Trên dữ liệu ×5, một mô hình tuyến tính đơn giản đang thắng

Kết quả mới nhất trên dữ liệu gấp năm lần, cùng 670 report validation. Mô hình attention sau 6 epoch đạt 64,2 phần trăm top-1, mất khoảng 4 giờ train. Một baseline đơn giản là TF-IDF cộng hồi quy logistic đạt 71,6 phần trăm, top-3 85,7 phần trăm, chỉ mất khoảng 4 phút. Ngay cả khi chỉ dùng thông tin tĩnh, nó đạt 63,6 phần trăm. Em hiểu kết quả này như sau: nhãn lấy từ antivirus gắn chặt với việc có hay không một API cụ thể, nên mô hình tuyến tính học rất nhanh; còn mô hình attention của em nhỏ và mới chạy 6 epoch, đường cong vẫn đang đi lên. Em trình bày thẳng kết quả này vì nó quyết định hướng tiếp theo: dùng TF-IDF làm mốc so sánh chính. Cấu hình được chốt trên validation rồi mới chấm test đúng một lần: TF-IDF đạt 73,2 và 70,2 phần trăm trên hai tập test, attention 61,3 và 64,1, khớp với validation. Em cũng thử ghép điểm hai mô hình nhưng không cải thiện.

Slide 18. Họ đủ mẫu đã đúng 89%; lỗi dồn vào họ ít mẫu và nhãn dễ nhầm

Câu hỏi quan trọng là mô hình sai ở đâu. Với các họ có từ 200 mẫu train trở lên, mô hình đã đúng 89 phần trăm. Với họ ít mẫu, chỉ còn 53 đến 58 phần trăm. Lỗi thường dồn về họ đông mẫu là agenttesla: snakelogger, taskun, noon, msilzilla bị đoán thành agenttesla. Nhiều tên trong số này là crypter, nên em cho rằng nhãn AVClass đang trộn vỏ đóng gói với payload. Điều này phù hợp với nghiên cứu MOTIF: so với nhãn do chuyên gia gán, nhãn AVClass chỉ đúng khoảng 47 phần trăm. Em đã thử năm cách cải tiến không cần train nặng, có kiểm định thống kê, và không cách nào vượt được khoảng 72 đến 73 phần trăm. Kết luận: trần nằm ở dữ liệu và nhãn, không nằm ở mô hình.

Slide 19. Một API riêng lẻ chưa đủ, phải đủ cả chuỗi mới xác nhận

Ngoài họ mã độc, hệ thống phân tích hành vi theo luồng thực thi trong sandbox. Ý tưởng là một API riêng lẻ thường vô hại; chỉ khi kết hợp thành chuỗi mới có ý nghĩa. Ví dụ Process Injection, T1055: mở một process khác, xin bộ nhớ trong đó, ghi mã vào, rồi tạo luồng chạy mã đó. Thấy một bước riêng lẻ thì bỏ qua, hai đến ba bước thì chỉ là suspected; phải đủ bốn bước, đúng thứ tự và cùng một process đích mới là confirmed. Mỗi hành vi được ánh xạ sang MITRE ATT&CK, MBC và NIST SP 800-53. Hiện có luật xác nhận cho 15 kỹ thuật ATT&CK, và các bằng chứng nhỏ như import, entropy hay hash không bao giờ tự thành confirmed. Bước tiếp theo là train mô hình

học hành vi đa nhãn, làm thí nghiệm chứng minh sự kết hợp thật sự có ích, và đo tỉ lệ nhận nhầm trên mẫu lành tính.

Slide 20. Còn cách mục tiêu 85% và chưa thắng baseline mạnh

Em xin nêu thẳng các hạn chế. Kết quả trên test còn cách mục tiêu 85 phần trăm. Validation bản cũ chỉ 181 report; bản mới có 670 report nhưng mới chạy một seed. Nhãn gộp từ nhiều antivirus nên có nhiễu, và có những họ mô hình chưa học. Mô hình attention chưa thắng baseline TF-IDF mạnh: 64,2 so với 71,6 phần trăm. Có 58 đến 63 phần trăm report train mới trùng imphash với test, có thể làm kết quả test lạc quan. Máy 16 GB giới hạn kích thước mô hình. Cuối cùng, trọng số attention chưa được kiểm chứng là lý do thật của mô hình.

Slide 21. Bước tiếp theo: sửa dữ liệu trước, rồi mới tới mô hình

Định hướng tiếp theo xuất phát từ phân tích lỗi: sửa dữ liệu trước, rồi mới tới mô hình. Bước một, đang làm: chuyển sang dữ liệu có nhãn tin cậy hơn. Avast-CTU gồm gần 49 nghìn report CAPE với nhãn do chuyên gia Avast gán, có ngày phát hiện để chia train và test theo thời gian. MOTIF là tập nhỏ có nhãn chuyên gia, dùng làm chuẩn kiểm tra. Cả hai đã được tải về. Bước hai, ngay trên máy này: tiếp tục hướng hành vi theo chuỗi, vì thứ tự event đã được chứng minh có ích, với mô hình lớn hơn và nhãn ATT&CK có sẵn từ CAPE. Bước ba, khi có GPU và nhóm: chạy nhiều seed, mô hình lớn, thêm mẫu lành tính để đo nhận nhầm và thử tấn công né tránh. Mục tiêu 85 phần trăm nên đặt lại trên dữ liệu có nhãn tin cậy; trên WinMET, cách thực tế là chỉ trả lời khi đủ chắc.

Slide 22. Cảm ơn thầy/cô đã lắng nghe

Em xin cảm ơn thầy cô đã lắng nghe. Danh sách tài liệu tham khảo đầy đủ theo chuẩn IEEE có trong báo cáo viết. Em sẵn sàng trả lời câu hỏi.